

Agent Vendor RFP - board one-pager

The questions to ask before signing an agent-platform contract. A non-answer on security, data, or compliance is itself a scored answer. The full 36-question RFP is in the templates.

Architecture & autonomy

1. What capability tier (L0-L4) does the product operate at, and can we cap it?
2. Can we require human approval on specific actions and enforce hard pre-execution limits?
3. Which models does it use, can we bring our own, and how are we insulated from a deprecation?

Security

4. How do you defend against direct and indirect prompt injection, and the lethal trifecta?
5. Do you have a third-party audit (SOC 2 / ISO 27001), and can we see it?
6. Is our data ever used to train shared models? How is data isolated between tenants?
7. What is your vulnerability disclosure and patch SLA? Have you had a disclosed incident?

Data & residency

8. What data do you collect and retain, for how long, and can we configure deletion?
9. Where is data processed and stored, and can we pin residency?

Reliability & cost

10. What are your uptime SLAs and the credits when missed?
11. What is the realistic all-in cost at 1x and 3x our expected volume?
12. What are the exit costs - data export format, migration support, notice period?

Evaluation & compliance

13. Will you run our eval set against the product before purchase?
14. What observability do we get - traces, per-step logs, cost attribution?
15. How does the product help us meet EU AI Act obligations (Art. 11 docs, Art. 12 logging, Art. 14 human oversight)?

Score every answer in the build-vs-buy harness. Weight security, data, and compliance heavily.